



TechSolutions Inc. Security Assessment

Final Project: Secure Access

Prepared for: TechSolutions Inc. **Prepared by:** Willie Conway **Date:** February 27, 2026 **Role:** IT Security Analyst

Executive Summary

This security assessment addresses the recent data breach at TechSolutions Inc. involving compromised credentials. The evaluation covers three critical areas: existing security infrastructure vulnerabilities, multifactor authentication (MFA) implementation, and physical security measures. Recommendations are provided to strengthen the organization's overall security posture and prevent future unauthorized access incidents.

Task 1: Evaluate Existing Security

Infrastructure (6 points)

Question 1.1: Identify Vulnerabilities (3 points)

Based on the recent data breach involving compromised credentials, identify and explain at least **THREE** vulnerabilities in TechSolutions Inc.'s current authentication infrastructure. For each vulnerability, explain how it may have contributed to the breach.

VULNERABILITY 1: Single-Factor Authentication Reliance

Vulnerability: Reliance on username and password as the sole authentication method for all systems and applications.

Explanation of how this vulnerability exists in the current setup: TechSolutions Inc. currently uses only username and password combinations for system and application access. This represents single-factor authentication (something you know), which is inherently vulnerable to credential theft through phishing, keylogging, password reuse attacks, and brute force attempts. Passwords alone cannot verify the legitimate user's identity—they only verify that someone possesses the correct credentials.

How this may have contributed to the breach: The breach involving compromised credentials was likely successful because once attackers obtained valid username/password combinations (through phishing, credential stuffing from other breaches, or other means), they had unimpeded access to all systems. There were no additional verification layers to stop them even after credentials were stolen. The attacker could have used these credentials to access email, internal databases, and other sensitive resources without triggering any alerts.

Risk Level (High/Medium/Low): High **Why:** Credential theft is one of the most common attack vectors, and without additional authentication factors, stolen credentials provide immediate, unrestricted access to all systems and sensitive data.

VULNERABILITY 2: SSH Key Management Issues

Vulnerability: Unmanaged or poorly managed SSH keys for remote server access.

Explanation of how this vulnerability exists in the current setup: The organization uses SSH keys to access remote servers, but there is no mention of key management policies, rotation schedules, or centralized key management. SSH keys are essentially long-term credentials that, if compromised, can provide persistent unauthorized access. Without proper management, keys may be shared among employees, never rotated, or left active after employees leave the organization.

How this may have contributed to the breach: Attackers who obtained initial access through compromised passwords may have discovered unmanaged SSH keys on compromised systems. These keys could provide access to additional servers, development environments, and databases without requiring further authentication. SSH keys often have more privileges than standard user accounts and can facilitate lateral movement through the network, potentially expanding the breach beyond the initial point of entry.

Risk Level (High/Medium/Low): High **Why:** SSH keys are powerful credentials that often grant privileged access. Without proper management and rotation, compromised keys can provide attackers with persistent, undetected access to critical systems.

VULNERABILITY 3: No Risk-Based or Contextual Authentication

Vulnerability: Absence of risk-based authentication that would detect and block anomalous access attempts.

Explanation of how this vulnerability exists in the current setup: The current authentication infrastructure appears to treat all login attempts equally—if the username and password are correct, access is granted regardless of context. There are no mechanisms to detect unusual patterns such as logins from unfamiliar geographic locations, impossible travel scenarios (logins from different countries within short timeframes), access at unusual hours, or access from new devices.

How this may have contributed to the breach: If an attacker obtained credentials and attempted to log in from a different country or at 3 AM local time, the current system would have granted access without any challenge. Modern security systems would flag such anomalous behavior, require additional verification, or block the attempt entirely. The absence of contextual authentication meant that even obviously suspicious login attempts succeeded, allowing the breach to occur and potentially continue undetected.

Risk Level (High/Medium/Low): Medium-High **Why:** While not directly preventing credential theft, contextual authentication provides critical detection capabilities and can stop attackers even when valid credentials are used in suspicious circumstances.

Question 1.2: Resource Access Assessment (3 points)

Review the eight resources that employees require access to. For each resource, identify the **CURRENT** authentication method used (from the list provided) and evaluate whether this method is appropriate given the sensitivity of the resource. Then, recommend whether MFA should be **REQUIRED**, **RECOMMENDED**, or **NOT NEEDED** for each resource.

RESOURCE ACCESS MATRIX

1. CORPORATE EMAIL SYSTEM

Field	Response
Current authentication method	Username and password
Sensitivity level	High
Is current method appropriate?	☐ Yes ☒ No

Field	Response
Explanation	Email systems contain sensitive communications, often serve as password reset vectors for other accounts, and are primary targets for attackers seeking to establish footholds in organizations. Password-only protection is inadequate.
MFA Recommendation	☒ Required ☐ Recommended ☐ Not Needed
Justification	Email is a primary attack vector and contains sensitive information. MFA significantly reduces the risk of account takeover even if credentials are compromised through phishing.

2. INTERNAL DATABASES

Field	Response
Current authentication method	Username and password
Sensitivity level	High
Is current method appropriate?	☐ Yes ☒ No
Explanation	Internal databases contain client details, project data, and financial records—the organization's most sensitive data assets. Password-only protection for these crown jewels is insufficient.
MFA Recommendation	☒ Required ☐ Recommended ☐ Not Needed
Justification	Database access should require the strongest available authentication given the sensitivity of the data. MFA is essential for protecting these core assets.

3. CLOUD STORAGE SERVICES

Field	Response
Current authentication method	Username and password
Sensitivity level	High
Is current method appropriate?	☐ Yes ☒ No
Explanation	Cloud storage contains documents, collaborative work, and potentially sensitive data. These services are accessible from anywhere, making them attractive targets.
MFA Recommendation	☒ Required ☐ Recommended ☐ Not Needed
Justification	Cloud services are particularly vulnerable to credential theft since they're internet-facing. MFA provides critical protection against unauthorized access.

4. HR SYSTEMS

Field	Response
Current authentication method	Username and password
Sensitivity level	High
Is current method appropriate?	☐ Yes ☒ No
Explanation	HR systems contain personal information of all employees, benefits data, and recruitment information. This data is subject to privacy regulations and is highly sensitive.
MFA Recommendation	☒ Required ☐ Recommended ☐ Not Needed
Justification	Personal data requires strong protection. MFA helps prevent identity theft and ensures compliance with privacy regulations.

5. CRM SOFTWARE

Field	Response
Current authentication method	Username and password
Sensitivity level	High
Is current method appropriate?	☐ Yes ☒ No
Explanation	CRM contains customer data, sales information, and business-critical relationship information. Compromise could damage customer trust and competitive position.
MFA Recommendation	☒ Required ☐ Recommended ☐ Not Needed
Justification	Customer data protection is both a security and reputational requirement. MFA should be mandatory.

6. PROJECT MANAGEMENT TOOLS

Field	Response
Current authentication method	Username and password
Sensitivity level	Medium
Is current method appropriate?	☐ Yes ☒ No
Explanation	While less sensitive than databases or HR systems, project tools contain intellectual property, timelines, and potentially confidential project information.
MFA Recommendation	☒ Required ☐ Recommended ☐ Not Needed
Justification	Given the breach history and the value of project information to competitors, MFA should be required for

Field	Response
	these tools as well.

7. DEVELOPMENT ENVIRONMENTS

Field	Response
Current authentication method	SSH keys
Sensitivity level	High
Is current method appropriate?	☐ Yes ☒ No
Explanation	SSH keys alone are insufficient without proper key management, rotation, and additional controls. Development environments contain source code, which is valuable intellectual property.
MFA Recommendation	☒ Required ☐ Recommended ☐ Not Needed
Justification	Development environments should require MFA for access, and SSH keys should be supplemented with additional factors or replaced with MFA-protected alternatives.

8. COMPANY INTRANET & KNOWLEDGE BASES

Field	Response
Current authentication method	Username and password
Sensitivity level	Low-Medium
Is current method appropriate?	☒ Yes ☐ No
Explanation	While intranet content is internal, much of it (policies, training materials) is less sensitive than other resources.

Field	Response
	However, some knowledge bases may contain sensitive information.
MFA Recommendation	☐ Required ☒ Recommended ☐ Not Needed
Justification	MFA should be recommended but could be prioritized after higher-risk systems. Consider segmenting sensitive knowledge base content requiring MFA separately.

Task 2: Create a Multifactor Authentication (MFA) Plan (3 points)

Question 2.1: MFA Method Selection (1.5 points)

Research and recommend THREE different types of MFA factors that TechSolutions Inc. could implement. For each factor, provide a specific example of a technology or method, explain how it works, and identify its pros and cons.

MFA FACTOR 1: SOMETHING YOU KNOW

Field	Response
Specific Technology/Method	Time-based One-Time Passwords (TOTP) via authenticator apps (Google Authenticator, Microsoft Authenticator, Authy)

How it works: TOTP generates temporary 6-8 digit codes based on a shared secret and the current time. The user installs an authenticator app on their smartphone, which is synchronized with the authentication server. When logging in, the user enters their password plus the current code displayed in the app. The code changes every 30 seconds, ensuring that even if a code is intercepted, it quickly becomes useless.

Pros:

- **No network required** – Codes work offline on the device
- **Free to implement** – No hardware costs for users
- **Industry standard** – Widely supported across platforms
- **Time-limited** – Codes expire quickly, reducing window of opportunity
- **No recurring costs** – No ongoing fees per user

Cons:

- **Requires smartphone** – Not all employees may have compatible devices
- **Device dependency** – If phone is lost, access is locked out until recovery
- **Manual entry** – Users must type codes, which can be cumbersome
- **No backup by default** – Requires planning for recovery codes
- **Phishing vulnerability** – Users can still be tricked into entering codes on fake sites

Best use case at TechSolutions: General employee population for email, project tools, and standard system access. Cost-effective and easy to deploy across the organization.

MFA FACTOR 2: SOMETHING YOU HAVE

Field	Response
Specific Technology/Method	FIDO2 Security Keys (YubiKey, Google Titan Key, etc.)

How it works: FIDO2 security keys are small hardware devices that connect via USB, NFC, or Bluetooth. During authentication, the user inserts the key and touches it (confirming presence). The key performs cryptographic authentication without revealing any shared secret to the server. This eliminates phishing risks because the key verifies the website's identity before authenticating.

Pros:

- **Phishing resistant** – Keys validate the legitimate site before responding
- **No code entry** – Simple touch or button press, no typing
- **Cryptographically secure** – Uses public key cryptography, no shared secrets

- **Portable** – Can be used across multiple devices
- **Durable** – Hardware tokens last for years

Cons:

- **Hardware cost** – \$20-50 per key, multiplied across workforce
- **Loss risk** – Keys can be lost or stolen
- **Management overhead** – Requires inventory and replacement processes
- **Compatibility** – Not all systems support FIDO2 yet
- **Requires backup** – Need at least two keys per user (primary + backup)

Best use case at TechSolutions: High-sensitivity access (databases, HR systems, admin accounts) and for technical staff accessing development environments. The phishing resistance justifies the cost for privileged access.

MFA FACTOR 3: SOMETHING YOU ARE

Field	Response
Specific Technology/Method	Biometric authentication (Windows Hello, Face ID, Touch ID, fingerprint scanners)

How it works: Biometric systems measure unique physical characteristics—fingerprints, facial features, iris patterns, or voice—and compare them against stored templates. Modern implementations store biometric data locally on the device in secure hardware (Trusted Platform Module or Secure Enclave), not on servers. The biometric unlocks a cryptographic key that authenticates to services.

Pros:

- **Convenient** – Fast, natural interaction, no passwords to remember
- **Always with you** – Can't be left at home like a token
- **Hard to forge** – Modern systems are resistant to spoofing
- **Integrated** – Built into modern laptops and phones at no extra cost
- **Local storage** – Biometric data never leaves the device

Cons:

- **Hardware requirements** – Requires compatible devices with biometric sensors
- **Privacy concerns** – Some users uncomfortable with biometric collection

- **False reject/accept rates** – Not 100% accurate
- **Cannot reset** – Unlike passwords, you can't change your fingerprint if compromised
- **Disability considerations** – May not work for all users

Best use case at TechSolutions: As a convenient second factor for mobile users and laptop-based authentication. Can be combined with PIN as fallback. Ideal for day-to-day access where security and convenience need balance.

Question 2.2: MFA Implementation Plan (1.5 points)

Develop a comprehensive MFA implementation plan for TechSolutions Inc.

MFA IMPLEMENTATION PLAN

RECOMMENDED FACTOR COMBINATIONS:

Resource Category	Primary Factors	Rationale
High-Sensitivity Resources (Internal Databases, HR Systems, CRM, Development Environments)	Password + FIDO2 Security Key	Maximum security with phishing resistance for most sensitive assets
Medium-Sensitivity Resources (Email, Cloud Storage, Project Tools)	Password + TOTP (Authenticator App)	Good security with lower cost and good user experience
Low-Sensitivity Resources (Intranet, Knowledge Bases)	Password + TOTP (optional for now)	Can phase in later; consider biometrics for convenience
Privileged Accounts (Admins, IT Staff)	Password + FIDO2 Security Key + TOTP backup	Defense in depth for highest-risk accounts

PHASED ROLLOUT APPROACH:

Phase	Timeline	Target Group	Systems Included	Success Criteria
Phase 1: Pilot	Week 1-2	IT Department (20 users)	Email, VPN, Admin systems	95% successful enrollment; <5% support tickets; all issues documented
Phase 2: Technical Staff	Week 3-4	Developers, IT, Security (50 users)	Email, Development environments, VPN	All Phase 1 criteria met; feedback collected
Phase 3: All Employees	Week 5-8	All employees (200+ users)	Email, Cloud Storage, Project Tools, VPN	90%+ enrollment; support tickets <10% of users
Phase 4: High-Sensitivity	Week 9-10	All with database/HR access	Internal Databases, HR Systems, CRM	All authorized users enrolled and using FIDO2 keys
Phase 5: Completion	Week 11-12	All users	All systems	98%+ enrollment; exception process documented; full system coverage

HANDLING EXCEPTIONS:

Legacy Systems Without MFA Support:

- **Option 1:** Deploy a reverse proxy or identity bridge (like Microsoft Entra ID Application Proxy) that adds MFA in front of legacy apps
- **Option 2:** Use a RADIUS server with MFA capability for systems that support RADIUS authentication
- **Option 3:** Isolate legacy systems with additional network controls and monitoring as compensating controls

- **Option 4:** Develop migration plan to replace or upgrade legacy systems within 12 months

Compensating Controls for Exceptions:

- Enhanced logging and monitoring for all legacy system access
- Shorter password expiration periods (30 days instead of 90)
- Restricted access based on network location (only from corporate IPs)
- Mandatory approval workflow for access requests
- Quarterly access reviews for all exception accounts

Emergency Access Procedures:

- **Break-glass accounts:** 2-3 emergency accounts with long complex passwords stored in a secure vault (physical safe) with dual-control access (two managers must approve)
 - **Offline backup codes:** Employees receive 10 one-time use recovery codes to store securely
 - **Emergency bypass:** IT helpdesk can issue temporary MFA bypass codes after verifying identity through multiple channels
 - **Service account review:** All service accounts documented and monitored; no interactive logon allowed
-

TRAINING AND CHANGE MANAGEMENT:

Employee Training Approach:

- **Pre-launch communications:** Email campaign explaining "why MFA" and the recent breach to build buy-in
- **Video tutorials:** 3-5 minute videos showing step-by-step enrollment for each MFA method
- **Lunch & learn sessions:** 30-minute sessions offered multiple times across shifts
- **Cheat sheets:** One-page quick reference guides with common scenarios
- **Drop-in clinics:** IT staff available in cafeteria during rollout weeks for hands-on help
- **Champions program:** Train super-users in each department to assist colleagues

Communication Strategy:

- **Week -2:** Announcement email from CEO/CIO explaining importance

- **Week -1:** Detailed instructions and schedule
- **Week 0:** Launch email with links to resources
- **Weekly:** Progress updates (enrollment percentages)
- **Just-in-time:** Reminders before each phase
- **Feedback loop:** Survey after each phase to identify improvements

Support Resources:

- **Dedicated helpdesk queue:** Priority for MFA issues
- **Knowledge base articles:** 10+ articles covering common issues
- **Self-service portal:** For recovery codes and device changes
- **Peer support:** Department champions
- **Executive concierge:** Dedicated support for executives

FALLBACK PROCEDURES (When MFA Unavailable):

Scenario	Procedure
Lost/Stolen Device	User calls helpdesk immediately to deactivate lost device; uses backup codes for immediate access; visits IT to provision new MFA device
Network/Service Outage	For TOTP apps, codes work offline; for cloud-based MFA, use offline backup codes; emergency access through VPN with local MFA validation
New Employee (before MFA enrollment)	Temporary password + mandatory MFA enrollment within 24 hours; limited system access until enrolled
VIP/Emergency Access	Pre-authorized backup codes; designated IT manager can approve temporary bypass (logged and audited)
Traveling without device	Use backup codes (printed and stored securely); IT can issue temporary hardware token
Phone broken/upgraded	Use backup codes; restore authenticator from backup if available; IT can reset MFA after identity verification

SUCCESS METRICS:

1. **Enrollment rate:** 98% of active users enrolled within 3 months

- 2. **Authentication success rate:** 99.5% of MFA attempts succeed first time
- 3. **Support ticket volume:** <10% of users require helpdesk assistance
- 4. **Mean time to resolve:** MFA issues resolved within 4 hours
- 5. **User satisfaction:** >80% positive feedback in post-implementation survey
- 6. **Security incidents:** Zero account takeovers on MFA-protected accounts
- 7. **Exception rate:** <2% of users on exception list
- 8. **Phishing simulation:** Significant reduction in credential submission on simulated phishing tests

Task 3: Evaluate Physical Security Measures (6 points)

Question 3.1: Identify Physical Security Vulnerabilities (3 points)

Analyze TechSolutions Inc.'s physical security measures and identify at least FIVE vulnerabilities. For each vulnerability, explain the potential risk and propose a specific remediation.

PHYSICAL SECURITY VULNERABILITY ASSESSMENT

VULNERABILITY 1: Reception and Lobby

Field	Response
Vulnerability	Visitor management relies solely on receptionist issuing temporary badges without any electronic verification, photo capture, or database check against watchlists. No expiration mechanism on badges.
Potential Risk	• Visitors could use fake identities to obtain badges • No record of visitor photos for post-incident investigation •

Field	Response
	Badges could be kept and reused days later since they don't expire • No integration with access control systems means badges don't restrict movement
Remediation Recommendation	• Implement electronic visitor management system (VMS) with photo capture and ID scanning
 • Check visitors against watchlists and databases
 • Print badges with expiration date/time and visitor photo
 • Integrate badges with electronic access control (badge opens only authorized doors)
 • Require pre-registration for all non-emergency visitors
Priority	High
Estimated Cost	\$\$\$

VULNERABILITY 2: Employee Workspace Entrances

Field	Response
Vulnerability	Back entrance to employee workspace opens directly to parking lot with only a sign reading "Authorized Personnel Only." The last employee leaving locks this door, creating inconsistent locking times and reliance on employee memory/reliability. No electronic access control on either entrance.
Potential Risk	• Unauthorized individuals can enter through back door by following employees or during the day when door is unlocked
 • No audit trail of who entered the workspace
 • Door may be left unlocked if last person forgets
 • Tailgating is completely undetectable
 • No way to remotely lock/unlock in emergency
Remediation Recommendation	• Install electronic card readers on both entrances
 • Require badge access for entry (employees only)
 • Implement anti-tailgating doors (mantraps or turnstiles) for high-security areas
 • Install CCTV covering both entrances
 • Automatic door closers with magnetic locks

Field	Response
	tied to fire alarm system • Centralized access control system with audit logging
Priority	High
Estimated Cost	\$\$\$

VULNERABILITY 3: Data Centers and Server Rooms

Field	Response
Vulnerability	Janitorial staff have access to server rooms alongside IT staff. Only lockable doors and basic environmental monitoring (thermostat/humidity) are in place. No multi-factor authentication for server room access.
Potential Risk	• Janitorial staff are not security-vetted to the same level as IT staff • Cleaning schedules provide opportunity for unauthorized access or device tampering • No video surveillance inside server rooms • No biometric or multi-factor authentication for most sensitive area • No breach detection (door forced open alarms) • Environmental monitoring lacks water detection, power monitoring
Remediation Recommendation	• Remove janitorial access; have IT staff handle cleaning or supervise all cleaning activities • Implement biometric or smart card + PIN access for server rooms • Install interior CCTV with 90-day retention • Add door forced-open and door held-open alarms • Enhance environmental monitoring (water detection, UPS monitoring, temperature/humidity logging with alerts) • Implement two-person rule for sensitive areas (requires two authorized people to enter) • Weekly access log reviews
Priority	Critical
Estimated Cost	\$\$\$

VULNERABILITY 4: Parking Lot Access

Field	Response
Vulnerability	Single entry point with fence and parking stickers, but no gate control, no license plate recognition, and no verification that vehicle matches sticker. Stickers can be easily duplicated or transferred between vehicles.
Potential Risk	• Unauthorized vehicles can enter by using copied or stolen stickers • No record of vehicle entry/exit times • No ability to block specific vehicles (terminated employees, known threats) • Parking lot provides proximity to back entrance, increasing tailgating risk • No visitor parking management
Remediation Recommendation	• Install automated gate with card reader or RFID reader for employee access • Implement license plate recognition (LPR) system integrated with employee database • Use tamper-evident stickers with unique barcodes • Maintain visitor parking registration at reception with time-limited access • Install CCTV covering parking lot entry and exit • Regular audits of parking permits
Priority	Medium
Estimated Cost	
	-\$

VULNERABILITY 5: Common Areas (Breakrooms and Restrooms)

Field	Response
Vulnerability	Common areas adjacent to work areas have no locks and are accessible without passing through secured entrances. No mention of surveillance in these transitional spaces.
Potential Risk	• Attackers could hide in common areas until after hours • These areas serve as staging points for tailgating into secure

Field	Response
	workspaces • No ability to secure building if someone remains in common areas • Cleaning staff and vendors have unsupervised access to these areas • Potential for unauthorized individuals to loiter and observe employee behavior
Remediation Recommendation	• Install CCTV covering common area entrances/exits
• Ensure common areas are within the secured perimeter (must pass through badge access to reach them)
• Implement after-hours lockdown where common areas are inaccessible
• Regular security patrols/sweeps before building lockdown
• Motion sensors in common areas after hours
• Clear sight lines from work areas to common areas
Priority	Medium
Estimated Cost	\$\$

ADDITIONAL VULNERABILITY 6: Meeting Rooms

Field	Response
Vulnerability	Meeting rooms have lockable doors and central calendar system, but no indication of who reserved rooms, no integration with access control, and no monitoring of meeting room activity.
Potential Risk	• Unauthorized individuals could reserve meetings to gain building access
• Sensitive discussions in unsecured meeting rooms
• No audit trail of who accessed meeting rooms
• Equipment in meeting rooms (projectors, conferencing systems) vulnerable to theft
• Whiteboards and flip charts may contain sensitive information
Remediation Recommendation	• Require badge access to book and enter meeting rooms
• Integrate calendar system with access control (room automatically unlocked for authorized attendees during booked time)
• Install cameras in common meeting areas (with appropriate signage)
• Provide secure whiteboards

Field	Response
	that can be erased/cleaned • Secure AV equipment in locked cabinets • Post-cleaning inspections to ensure no sensitive materials left behind
Priority	Medium
Estimated Cost	\$\$

Question 3.2: Visitor Management and Access Control Enhancement (3 points)

Design a comprehensive visitor management and access control enhancement plan.

VISITOR MANAGEMENT AND ACCESS CONTROL ENHANCEMENT PLAN

1. VISITOR REGISTRATION AND CHECK-IN PROCESS

Pre-registration (Recommended for planned visits):

- Host employee submits visitor registration through internal portal at least 24 hours in advance
- Portal captures: visitor full name, company, email, phone, government ID number (last 4 digits), purpose of visit, expected duration, and areas to be accessed
- Host must approve and acknowledge responsibility for visitor
- System generates QR code confirmation sent to visitor's email
- Background check can be performed in advance for sensitive areas

Same-day Registration:

- Visitor presents government-issued ID at reception
- Receptionist scans ID (or enters manually if scanning unavailable)
- System captures visitor photo via webcam

- Host is contacted for verification and must come to reception
- No unescorted access for same-day visitors

Check-in Workflow:

Step	Action	System Response
1	Visitor arrives at reception	Greeted by receptionist
2	Presents ID (or QR code if pre-registered)	ID scanned/photographed
3	System checks against watchlist	If match, security notified
4	Photo taken	Added to visitor record
5	Host notified	Host receives notification
6	Visitor signs non-disclosure agreement (digital)	Stored in visitor record
7	Badge printed	Access rights activated
8	Host escorts visitor	Escort begins

Identity Verification Requirements:

- Government-issued photo ID required for all visitors
- ID must be current (not expired)
- For non-English IDs, secondary verification may be required
- Passport, driver's license, or national ID card accepted
- IDs scanned and stored in encrypted visitor database
- IDs checked against global watchlists and internal databases

2. VISITOR BADGE SYSTEM

Badge Type	Color	Access Level	Expiration	Photo?	Features
One-day Visitor	White	Escorted only; no electronic access	End of day (6 PM)	Yes	"ESCORT REQUIRED" printed; no RFID
Multi-day Visitor	Yellow	Specific areas only	Date-specific (max 5 days)	Yes	RFID enabled for authorized

Badge Type	Color	Access Level	Expiration	Photo?	Features
		(pre-approved)			areas
Contractor (Short-term)	Orange	Assigned work areas only	Project end date	Yes	RFID enabled; time-limited
Contractor (Long-term)	Blue	Assigned areas + common areas	30-90 days	Yes	RFID + photo; requires training
VIP/Executive Guest	Gold	Escorted by executive	End of day	Optional	Distinctive design; minimal restrictions
Emergency Services	Red	All areas (emergency only)	Single incident	No	Issued to verified personnel; tracked
Temporary Employee	Green	Assigned areas only	Employment duration	Yes	Same as employee but time-limited

Badge Features:

- **Photo identification:** All badges (except emergency) include visitor photo
- **Color coding:** Instant visual identification of visitor type
- **Expiration display:** Prominently shows expiration date/time
- **RFID/NFC:** Electronic access control integration (where authorized)
- **Tamper-evident:** Special materials that show if tampered with
- **Return required:** Design encourages return (large "RETURN TO RECEPTION" text)
- **QR code:** Encrypted verification code for quick lookup

3. ESCORT AND MONITORING REQUIREMENTS

Escort Policy:

- **Unescorted access allowed for:**
 - Long-term contractors (after training and background check)
 - Visitors with "unescorted" specifically approved (rare)
 - Areas designated as public/common areas only
- **Escort required for:**
 - All one-day visitors
 - All visitors accessing sensitive areas (server rooms, HR, finance)
 - All visitors without RFID-enabled badges
 - All visitors during non-business hours
- **Escort-to-visitor ratio:** Maximum 1:3 (one escort may escort up to 3 visitors)
- **Escort responsibilities:**
 - Remain with visitors at all times
 - Ensure visitors do not access unauthorized areas
 - Report any suspicious behavior immediately
 - Return visitors to reception for check-out

Monitoring During Visit:

- CCTV coverage in all common areas and workspaces
- Electronic access logs record every badge swipe
- Real-time alerts for:
 - Attempted access to unauthorized areas
 - Badge used outside of approved hours
 - Expired badge attempt
 - Multiple failed access attempts
- Periodic security rounds check on visitors
- Host receives reminder when visitor is approaching check-out time

Restricted Areas:

Area	Access Requirement
Server Rooms	No visitors (IT escort only for essential maintenance)
HR/Payroll	No visitors (pre-arranged meetings only with escort)

Area	Access Requirement
Executive Offices	Escort required at all times
R&D/Labs	No visitors (special approval required)
Finance	No visitors (pre-arranged only with escort)
IT Operations	Escort required; pre-approval needed

4. INTEGRATION WITH ELECTRONIC ACCESS CONTROL

Access Control Integration:

- Visitor management system (VMS) integrated with physical access control system (PACS)
- When badge is issued, access rights automatically provisioned in PACS
- Rights based on:
 - Visitor type
 - Approved areas (from registration)
 - Time of day restrictions
 - Expiration time
- Integration with Active Directory for employee verification
- Real-time synchronization between VMS and PACS
- Mobile credentials available for approved contractors (phone-based access)

Temporary Access Rights:

Element	Specification
How assigned	Automatically based on pre-approved access level; manually overridden only by security manager
Duration	Matches badge expiration; auto-revoked at expiration
Time restrictions	Default 8 AM - 6 PM; extended only with approval

Element	Specification
Area restrictions	Only pre-approved zones; all others blocked
Revocation method	Automatic at expiration; immediate on check-out; manual by security

Tracking and Logging:

- Every badge swipe logged with:
 - Timestamp
 - Location (reader ID)
 - Badge ID
 - Associated visitor record
 - Success/failure
- Logs retained for minimum 90 days
- Integration with SIEM for real-time alerting
- Daily access report to security team
- Weekly review of unusual access patterns

5. CHECK-OUT AND BADGE RETURN PROCEDURES

Standard Check-out Process:

Step	Action	Verification
1	Visitor returns to reception	Escort may accompany
2	Visitor presents badge	Receptionist scans badge
3	System confirms badge returned	Updates visitor record
4	Deactivate badge	Access rights immediately revoked
5	Return ID if held	Visitor retrieves ID
6	Sign out (optional)	Digital record completed

After-hours Check-out:

- Designated after-hours check-out station with secure badge drop box
- Badge deposited in locked container

- System deactivates badge at midnight if not returned
- Visitor must return next business day to complete process

Return Confirmation:

- Email confirmation sent to host and visitor
 - Visitor record marked as completed
 - Audit trail shows check-out time and method
 - Any discrepancies flagged for security review
-

6. HANDLING OF LOST OR UNRETURNED BADGES

Lost Badge Procedure:

Timeframe	Action
Immediate	Visitor reports loss to host; host notifies security
Within 5 minutes	Security deactivates badge in access control system
Within 15 minutes	Security reviews access logs for any unauthorized use
Within 1 hour	Security alerts guards to watch for badge; review CCTV
Within 24 hours	Incident report filed; visitor management updated

Unreturned Badge Procedure:

Scenario	Action
Visitor left without checking out	Security deactivates badge immediately; contact host to locate visitor
Badge not returned by end of day	Automatic deactivation at expiration time; email reminder to host
Contractor badge not returned	Final paycheck withheld until badge returned; legal notification if necessary
Employee termination badge	Standard termination process includes badge return; final check withheld if not returned

Deactivation Timeline:

- **Immediate actions:** Lost/stolen badges deactivated within 5 minutes

- **Within 1 hour:** All related access rights reviewed and verified
- **Within 24 hours:** Incident documentation complete
- **Within 7 days:** Review of process to identify improvements

Escalation Process:

1. **Level 1:** Security deactivates badge and searches
2. **Level 2:** If badge used after reported lost, involve law enforcement
3. **Level 3:** If sensitive area accessed, mandatory breach investigation
4. **Level 4:** Process review and potential disciplinary action if employee negligence

7. TECHNOLOGY RECOMMENDATIONS

Technology	Purpose	Estimated Cost
Visitor Management System (VMS)	Digital visitor registration, watchlist checks, badge printing	5,000 – 10,000 <i>initial</i> + 2,000/year
ID Scanner	Scan and verify government IDs	\$500-1,000 per unit
Badge Printer	On-site photo badge printing	\$1,000-2,000
Access Control System Upgrade	Electronic readers at all doors	\$20,000-50,000
CCTV System Enhancement	Additional cameras at entrances and common areas	\$10,000-25,000
License Plate Recognition	Parking lot entry/exit monitoring	\$5,000-15,000
Integration Software	Connect VMS to access control and HR systems	\$5,000-10,000
Training and Implementation	Staff training and system configuration	\$5,000-10,000

Justification:

- Prevent credential sharing and unauthorized access
- Create audit trails for compliance and investigations

- Reduce reliance on human vigilance alone
- Enable real-time alerts and automated responses
- Improve visitor experience while maintaining security
- Meet regulatory compliance requirements

Estimated Total Budget: 55,000–125,000 (depending on scope)

8. TRAINING REQUIREMENTS

Receptionist Training:

- Visitor management system operation
- ID verification techniques
- Watchlist recognition and escalation procedures
- Emergency response protocols
- De-escalation techniques for difficult visitors
- Badge printing and troubleshooting
- Check-in/check-out procedures

Employee Training:

- How to register visitors (pre-registration process)
- Escort responsibilities and expectations
- Recognizing and reporting suspicious behavior
- Not allowing tailgating
- Importance of visitor management to security
- Procedure for lost visitor badges

Security Team Training:

- Advanced VMS administration
- Access control system management
- Incident response for security breaches
- Investigation techniques using visitor logs
- Report generation and analysis
- Integration troubleshooting
- Emergency override procedures

Annual Refresher Training:

- All staff receive annual security awareness training including visitor management updates
 - Quarterly security bulletins with lessons learned
 - New hire orientation includes visitor procedures
-

Conclusion and Recommendations Summary

This security assessment has identified significant vulnerabilities in TechSolutions Inc.'s authentication infrastructure and physical security measures. The recent credential-based breach highlights the urgent need for enhanced security controls.

Priority Recommendations:

Immediate (30 days):

1. Begin MFA rollout starting with IT department pilot
2. Enhance server room access controls (remove janitorial access, add CCTV)
3. Implement electronic visitor management with photo badges
4. Install electronic access control on employee workspace entrances

Short-term (90 days):

1. Complete MFA rollout to all employees
2. Implement parking lot access controls
3. Add environmental monitoring enhancements to server rooms
4. Deploy additional CCTV coverage

Long-term (6-12 months):

1. Upgrade legacy systems to support modern authentication
2. Implement biometric access for sensitive areas
3. Achieve zero standing privileges for administrative access

4. Regular security audits and penetration testing

By implementing these recommendations, TechSolutions Inc. can significantly reduce the risk of future credential-based breaches and strengthen the overall security posture of the organization.

Submitted by: Willie Conway **Title:** IT Security Analyst **Date:** February 27, 2026
Version: 1.0
